MSUG 2025-02-27

TIETOMURTO TUTKINTA MICROSOFT 365 MAAILMASSA

JUUSO MYLLYLÄ

elisa

$ WHOAMI

JUUSO MYLLYLÄ

TYÖ
DFIR @ Elisa

KOKEMUS
DFIR
Threat Hunting
Detection Engineering
Security Operations Center

KOULUTUS
Kyberturvallisuuden maisteri, Jyväskylän yliopisto

SERTIFIOINNIT
GIAC Certified Forensic Analyst (GCFA)

VAPAA-AIKA
Uhkametsä podcastin juontaja

BUSINESS EMAIL COMPROMISE (BEC)

2023 CRIME TYPES continued

By Complaint Loss			
Crime Type	*Loss*	*Crime Type*	*Loss*
Investment	$4,570,275,683	Extortion	$74,821,835
BEC	$2,946,830,270	Employment	$70,234,079
Tech Support	$924,512,658	Ransomware*	$59,641,384
Personal Data Breach	$744,219,879	SIM Swap	$48,798,103
Confidence/Romance	$652,544,805	Overpayment	$27,955,195
Data Breach	$534,397,222	Botnet	$22,422,708
Government Impersonation	$394,050,518	Phishing/Spoofing	$18,728,550
Non-payment/Non-Delivery	$309,648,416	Threats of Violence	$13,531,178
Other	$240,053,059	Harassment/Stalking	$9,677,332
Credit Card/Check Fraud	$173,627,614	IPR/Copyright and Counterfeit	$7,555,329
Real Estate	$145,243,348	Crimes Against Children	$2,031,485
Advanced Fee	$134,516,577	Malware	$1,213,317
Identity Theft	$126,203,809		
Lottery/Sweepstakes/Inheritance	$94,502,836		

*Descriptors***			
Cryptocurrency	$3,809,090,856	Cryptocurrency Wallet	$1,778,399,729

*Regarding ransomware adjusted losses, this number does not include estimates of lost business, time, wages, files, or equipment, or any third-party remediation services acquired by an entity. In some cases, entities do not report any loss amount to the FBI, thereby creating an artificially low overall ransomware loss rate. Lastly, the number only represents what entities report to the FBI via the IC3 and does not account for the entity direct reporting to FBI field offices/agents.

MISTÄ ON KYSE?

https://www.kyberturvallisuuskeskus.fi/fi/tietomurtoaalto-leviaa-organisaatiosta-toiseen-katkaise-tietojenkalastelu

TIETOMURTOTUTKINTA JA M365

”HENKILÖTIETOIHIN KOHDISTUNEESTA TIETOTURVALOUKKAUKSESTA ON ILMOITETTAVA TIETOSUOJAVALTUUTETUN TOIMISTOLLE”.

- Tietosuojavaltuutetun toimisto, 2025.

https://tietosuoja.fi/office-365

TIETOMURTOTUTKINTA JA M365

”OFFICE 365 -HYÖKKÄYKSEEN LIITTYEN TIETOSUOJAVALTUUTETUN TOIMISTO PYYTÄÄ TAVALLISESTI SEURAAVAT LISÄSELVITYKSET. TIEDOT TOIMIVAT MYÖS TIETOTURVALOUKKAUKSEN DOKUMENTAATIONA. TARVITTAESSA VOIDAAN PYYTÄÄ ESIMERKIKSI ENEMMÄN LOKITIETOJA”.

- Tietosuojavaltuutetun toimisto, 2025.

https://tietosuoja.fi/office-365

LISÄSELVITYKSET

1. Onko tileille tullut luvattomia uudelleenlähetyssääntöjä?
2. Jos on, mihin sähköpostiosoitteeseen ne johtavat?
3. Onko tilille kirjauduttu luvattomasti tuona aikana (esimerkiksi Azure AD -tunnuksen audit log)?
4. Jos kirjautumisia on tapahtunut, onko sähköposteja ladattu (esimerkiksi Office 365 Exchange -lokit)?
5. Onko tilillä ollut käytössään OneDrive- tai Sharepoint-palveluita?
6. Onko tilien sähköposteissa, OneDrivessa tai Sharepoint-palveluissa henkilötietoja?
7. Jos on, kuinka monen henkilön tietoja näissä palveluissa on ja mihin henkilötietoryhmiin ne kuuluvat (esimerkiksi nimi, henkilötunnus, sähköposti, osoite)?
8. Onko organisaatiossa harkittu käytettäväksi monen tekijän tunnistautumista (MFA)?
9. Miten paljon ja mitä henkilötietoryhmiä organisaation Global Address List sisältää?
10. Toimita tietosuojavaltuutetun toimistolle vuodettujen tunnusten osalta niiden Azure AD:n SIGN-INS -loki hyökkäyksen ajalta (csv-tiedosto).
11. Toimita hyökkääjien lähettämä sähköposti, joka sisältää linkit.
12. Toimita mailtrace-loki hyökkääjän lähettämien sähköpostien osalta.

https://tietosuoja.fi/office-365

elisa

TAVOITE

https://www.spectator.co.uk/wp-content/uploads/2022/05/Mary_iStock.jpg

https://upload.wikimedia.org/wikipedia/commons/thumb/e/e5/Microsoft_Purview_Logo.svg/2048px-Microsoft_Purview_Logo.svg.png

TUTKINTATEHTÄVÄT - TIETOSUOJAVALTUUTETTU

1. LISTAA MURRETUN KÄYTTÄJÄTUNNUKSEN KIRJAUTUMISTAPAHTUMAT
2. TUTKI SÄHKÖPOSTIEN LUKEMISEEN JA LATAAMISEEN LIITTYVÄT TAPAHTUMAT
3. TARKISTA SÄHKÖPOSTILAATIKKOON ASETETUT SÄHKÖPOSTIN KÄSITTELYSÄÄNNÖT
4. LISTAA KAIKKI VAARANTUNEET TIEDOSTOT

TUTKINTATEHTÄVÄT - LISÄTUTKINTA

1. SELVITÄ MURRETULLE TILILLE REKISTERÖIDYT LAITTEET
2. TARKISTA UUSIEN MONIVAIHEISTEN TUNNISTAUTUMISMENETELMIEN (MFA) LISÄYS TILILLE
3. KOLMANSIEN OSAPUOLIEN PALVELUIHIN KIRJAUTUMINEN MURRETULLA TILILLÄ
4. ANALYSOI TILILLE REKISTERÖIDYT APPLIKAATIOT

TUTKINTATEHTÄVÄT – AUDIT LOG

Juuso Myllylä | Audit logs

User

Search

- Overview
- Audit logs
- Sign-in logs
- Diagnose and solve problems
- Custom security attributes
- Assigned roles
- Administrative units
- Groups
- Applications
- Licenses
- Devices
- Azure role assignments
- Authentication methods
- New support request

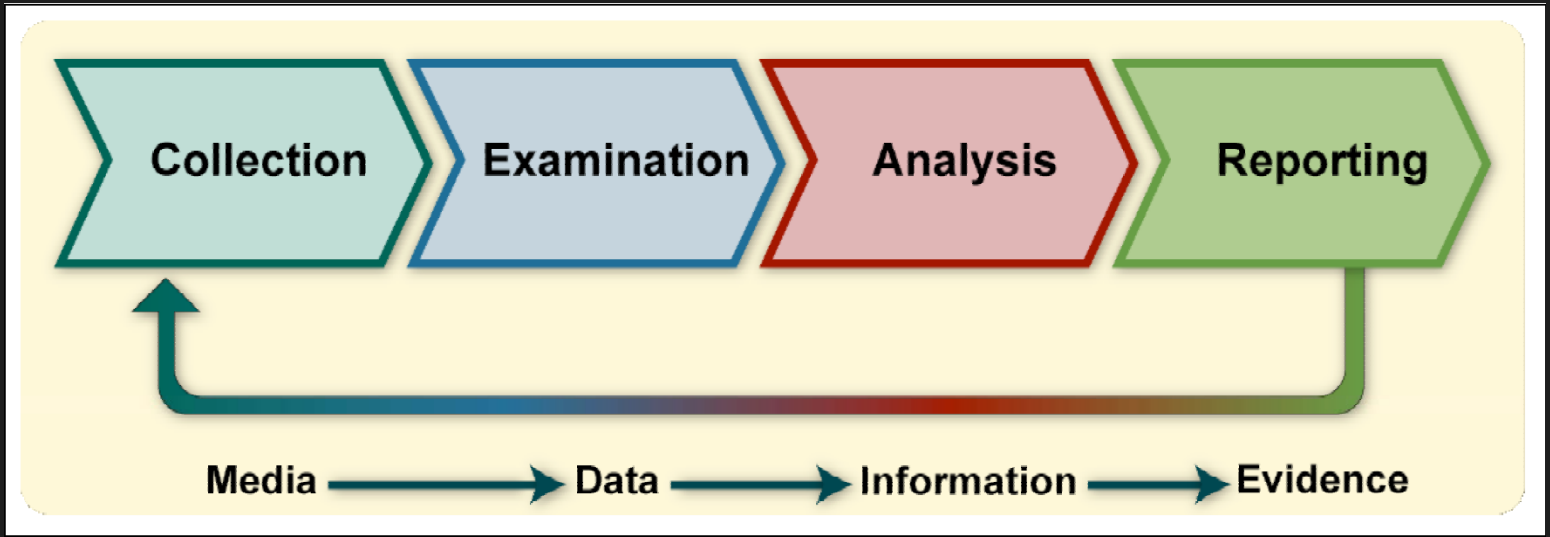
Download | Refresh | Columns | Got feedback?

This view will soon be replaced with a view that includes custom security attribute logs, infinite scrolling, and column reordering. Try out our new audits preview. →

Date : **Last 1 month** | Show dates as : **UTC** | Service : **All** | Category : **All** | Activity : **All** | Add filters

Date (UTC)	Service	Category	Activity	Status	Status reason	Target(s)	Initiated by (actor)
2/21/2025, 3:43:48 PM	Core Directory	UserManagement	Update user	Success		juuso.myllyla@esmsoctest.onmicrosoft.com	Azure MFA StrongAuthentica...
2/20/2025, 1:01:44 PM	Core Directory	UserManagement	Update user	Success		juuso.myllyla@esmsoctest.onmicrosoft.com	Azure MFA StrongAuthentica...
2/19/2025, 12:34:53 PM	Core Directory	GroupManagement	Add member to group	Failure	Microsoft.Online.DirectorySer...	juuso.myllyla@esmsoctest.onmicrosoft.com, 1fb...	Microsoft Teams Services
2/19/2025, 12:34:34 PM	Core Directory	UserManagement	Enable account	Success		juuso.myllyla@esmsoctest.onmicrosoft.com	[redacted]@esmsocte...
2/19/2025, 12:34:34 PM	Core Directory	UserManagement	Update user	Success		juuso.myllyla@esmsoctest.onmicrosoft.com	[redacted]@esmsocte...
2/19/2025, 12:23:54 PM	Core Directory	UserManagement	Disable account	Success		juuso.myllyla@esmsoctest.onmicrosoft.com	Radius Aad Syncer
2/19/2025, 12:23:54 PM	Core Directory	UserManagement	Update user	Success		juuso.myllyla@esmsoctest.onmicrosoft.com	Radius Aad Syncer
2/19/2025, 11:38:59 AM	Core Directory	UserManagement	Update user	Success		juuso.myllyla@esmsoctest.onmicrosoft.com	Azure MFA StrongAuthentica...
2/18/2025, 6:18:49 AM	Core Directory	UserManagement	Update user	Success		juuso.myllyla@esmsoctest.onmicrosoft.com	Azure MFA StrongAuthentica...
2/18/2025, 6:17:28 AM	Core Directory	UserManagement	Update user	Success		juuso.myllyla@esmsoctest.onmicrosoft.com	Azure MFA StrongAuthentica...

TIETOMURTOTUTKINTA 101



NIST SP 800-86 FORENSIC PROCESS

https://nvlpubs.nist.gov/nistpubs/legacy/sp/nistspecialpublication800-86.pdf

TUTKINTA-AINEISTON KERÄYS

https://upload.wikimedia.org/wikipedia/commons/thumb/e/e5/Microsoft_Purview_Logo.svg/2048px-Microsoft_Purview_Logo.svg.png

TUTKINTA-AINEISTON KERÄYS

https://upload.wikimedia.org/wikipedia/commons/thumb/e/e5/Microsoft_Purview_Logo.svg/2048px-Microsoft_Purview_Logo.svg.png

https://upload.wikimedia.org/wikipedia/commons/thumb/8/8c/Microsoft_Entra_ID_color_icon.svg/1200px-Microsoft_Entra_ID_color_icon.svg.png

TUTKINTA-AINEISTON KERÄYS

https://upload.wikimedia.org/wikipedia/commons/thumb/e/e5/Microsoft_Purview_Logo.svg/2048px-Microsoft_Purview_Logo.svg.png

https://upload.wikimedia.org/wikipedia/commons/thumb/8/8c/Microsoft_Entra_ID_color_icon.svg/1200px-Microsoft_Entra_ID_color_icon.svg.png

https://upload.wikimedia.org/wikipedia/commons/thumb/a/a4/Windows-defender.svg/230px-Windows-defender.svg.png

Microsoft 365

● = Included
+ = Available by adding Teams Enterprise/Teams EEA

	Information Worker Plans													Frontline Worker Plans							
	Microsoft 365				Office 365			Microsoft Teams Enterprise/ Teams EEA	Enterprise Mobility + Security		Windows 11			Microsoft 365							Office 365
	E3 (no Teams)[1]	E5 (no Teams)[1]	E5 Security[2]	E5 Compliance[2]	E1 (no Teams)[1]	E3 (no Teams)[1]	E5 (no Teams)[1]		E3	E5	Pro (for reference)	Enterprise E3	Enterprise E5	F1	F1 (no Teams)[1]	F3	F3 (no Teams)[1]	F5 Security[3]	F5 Compliance[2]	F5 Sec+Comp[3]	F3[4]
Threat protection																					
Microsoft Defender Antimalware	●	●										●	●			●	●				●
Microsoft Defender Firewall	●	●										●	●			●	●				
Microsoft Defender Exploit Guard	●	●										●	●			●	●				
Microsoft Defender Credential Guard	●	●										●	●			●	●				
BitLocker and BitLocker To Go	●	●										●	●			●	●				
Microsoft Defender for Endpoint Plan 1	●	●																			
Microsoft Defender for Endpoint Plan 2		●	●										●					●		●	
Microsoft Defender for IoT – Enterprise IoT		●	●																		
Microsoft Defender for Identity		●	●							●								●		●	
Microsoft Defender for Office 365 Plan 2		●	●				●											●		●	
Microsoft Defender Application Guard for Edge	●	●										●	●			●	●				
Microsoft Defender Application Guard for Office		●	●															●		●	
Safe Documents		●	●															●		●	
Data lifecycle management																					
Manual retention labels	●	●			●	●	●		●	●				●	●	●	●				●
Basic org-wide or location-wide retention policies	●	●				●	●												●	●	
Rules-based automatic retention policies		●		●			●												●	●	
Machine Learning-based retention		●		●															●	●	
Teams message retention policies	+	+		●[1]	+[2]	+[2]	+[2]	●[1]						●[2]		●[2]			●[1,2]	●[1,2]	●[2]
Records Management		●		●			●												●	●	

[1] Includes EEA (no Teams) plans.
[2] Requires Microsoft 365 E3 (or Office 365 E3 and Enterprise Mobility + Security E3).

[1] Requires Microsoft 365 F1/F3 (or Office 365 F3 and Enterprise Mobility + Security E3).
[3] Not available for new customer purchases in Volume Licensing or Web Direct channels.

[1] Requires Teams Enterprise when added to Microsoft 365/Office 365 (no Teams) plans and Teams EEA when added to Microsoft 365/Office 365 EEA (no Teams) plans.
[2] 30-day minimum retention period. (No maximum retention period.)

eDiscovery and auditing																					
Content Search	●	●		●	●	●	●	●						●	●	●	●				●
eDiscovery (Standard) (including Hold and Export)	●	●		●		●	●												●	●	
Litigation Hold	●	●				●	●												●	●	
eDiscovery (Premium)		●		●			●												●	●	
Audit (Standard)	●	●			●	●	●	●						●	●	●	●				●
Audit (Premium)		●		●			●												●	●	

https://www.microsoft.com/en-us/microsoft-365/enterprise/microsoft365-plans-and-pricing

E3 VS E5 lisenssi

Comparison of key capabilities

The following table compares the key capabilities available in Audit (Standard) and Audit (Premium). All Audit (Standard) functionality is included in Audit (Premium).

Expand table

Capability	Audit (Standard)	Audit (Premium)
Enabled by default	✓	✓
Thousands of searchable audit events	✓	✓
Audit search tool in the Microsoft Purview portal and compliance portal	✓	✓
Audit Search Graph API	✓	✓
Search-UnifiedAuditLog cmdlet	✓	✓
Export audit records to CSV file	✓	✓
Access to audit logs via Office 365 Management Activity API [1]	✓	✓
180-day audit log retention	✓	✓
1-year audit log retention		✓
10-year audit log retention [2]		✓
Audit log retention policies		✓
Intelligent insights		✓

Lokakuusta 2023 eteenpäin E3 lisenssillä näkee samat tapahtumat kuin E5 lisenssillä!

https://www.microsoft.com/en-us/security/blog/2023/10/18/expanding-audit-logging-and-retention-within-microsoft-purview-for-increased-security-visibility/

https://learn.microsoft.com/en-us/purview/audit-solutions-overview

M365 tutkinnan edellytykset

Security Operator

PRIVILEGED

This is a privileged role. Users with this role can manage alerts and have global read-only access on security-related features, including all information in Microsoft 365 Defender portal, Microsoft Entra ID Protection, Privileged Identity Management and Microsoft Purview compliance portal. For more information about Office 365 permissions, see Roles and role groups in Microsoft Defender for Office 365 and Microsoft Purview compliance.

Expand table

In	Can do
Microsoft 365 Defender portal	All permissions of the Security Reader role View, investigate, and respond to security threats alerts Manage security settings in Microsoft 365 Defender portal
Microsoft Entra ID Protection	All permissions of the Security Reader role Perform all ID Protection operations except for configuring or changing risk-based policies, resetting passwords, and configuring alert e-mails.
Privileged Identity Management	All permissions of the Security Reader role
Microsoft Purview compliance portal	All permissions of the Security Reader role View, investigate, and respond to security alerts
Microsoft Defender for Endpoint	All permissions of the Security Reader role View, investigate, and respond to security alerts When you turn on role-based access control in Microsoft Defender for Endpoint, users with read-only permissions such as the Security Reader role lose access until they are assigned a Microsoft Defender for Endpoint role.
Intune	All permissions of the Security Reader role
Microsoft Defender for Cloud Apps	All permissions of the Security Reader role View, investigate, and respond to security alerts
Microsoft 365 service health	View the health of Microsoft 365 services

M365 tutkintaan tarvitaan riittävät oikeudet. Tutkinnallisesta kulmasta Security Operator rooli riittää.

Suositeltavaa käyttää Privileged Identity Manager (PIM)!

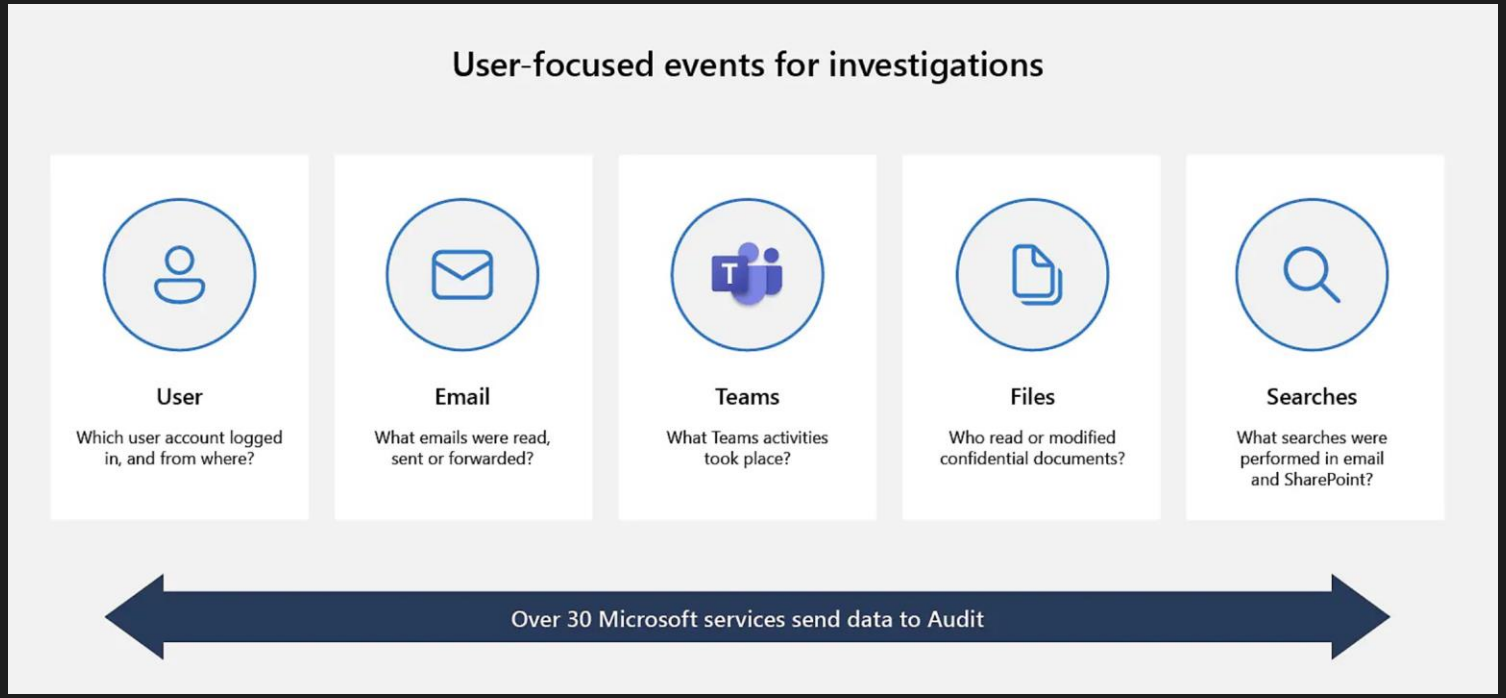
https://learn.microsoft.com/en-us/entra/identity/role-based-access-control/permissions-reference#security-operator

TUTKINTA-AINEISTON ARVIOIMINEN

“After data has been collected, the next phase is to examine the data, which involves assessing and extracting the relevant pieces of information from the collected data”.

- NIST SP 800-86

TUTKINTA-AINEISTON ARVIOIMINEN



https://www.microsoft.com/en-us/security/business/risk-management/microsoft-purview-audit

TUTKINTA-AINEISTON ANALYYSI

“The foundation of forensics is using a methodical approach to reach appropriate conclusions based on the available data or determine that no conclusion can yet be drawn”.

- NIST SP 800-86

ANALYYSI – KUSTO QUERY LANGUAGE

```
KQL BASICS

// 1. Taulu
AlertEvidence
// 2. Aikafiltteri
| where Timestamp between (datetime(2025-02-19) .. 1d)
// 3. Hakuehdot
| where AccountUpn == "juuso.myllyla@esmsoctest.onmicrosoft.com"
// 4. Tulosten aggregointi
| project TimeGenerated, Title, ServiceSource, EntityType, RemoteIP, Severity
```

elisa

ANALYYSI – KIRJAUTUMISTAPAHTUMAT

DEMO 1

ANALYYSI – KIRJAUTUMISTAPAHTUMAT

TÄRKEIMMÄT HUOMIOT

1. Älä luota IP osoitteen geolokaatioon
2. Kerää talteen IOC tietoa seuraavia vaiheita varten
3. Selvitä uhkatoimijan pääsyn kesto
4. Ota kirjautumistapahtumista CSV talteen
5. BONUS: Tarkista samaan vauhtiin muiden käyttäjien mahdolliset kirjautumiset IOC tietoja vastaan

ANALYYSI – SÄHKÖPOSTIEN LUKU JA LATAUS

DEMO 2

ANALYYSI – SÄHKÖPOSTITAPAHTUMAT

TÄRKEIMMÄT HUOMIOT

1. KQL parhaita ominaisuuksia on eri taulujen yhdistäminen
2. Asiat voi löytää monella tavalla, tee siten kuin on helpointa
3. Käytä IOC tietoa rajaavana tekijänä koska pystymme näkemään viestintäsalaisuuden piirissä olevaa tietoa

elisa

ANALYYSI - SÄHKÖPOSTITAPAHTUMAT

DEMO 3

ANALYYSI – SÄHKÖPOSTITAPAHTUMAT

TÄRKEIMMÄT HUOMIOT

1. Ymmärrä, mitä dataa löytyy mistäkin taulusta
2. KQL on todella tehokas (ja välillä hankala) hakukieli
3. Sama data voi löytyä monesta paikasta, Advanced Hunting keskitetty sijainti kaikelle datalle

elisa

ANALYYSI – VAARANTUNEET TIEDOSTOT

DEMO 4

ANALYYSI – VAARANTUNEET TIEDOSTOT

TÄRKEIMMÄT HUOMIOT

1. Ymmärrä, mitä dataa löytyy mistäkin taulusta
2. KQL on todella tehokas (ja välillä hankala) hakukieli
3. Sama data voi löytyä monesta paikasta, Advanced Hunting keskitetty sijainti kaikelle datalle

elisa

ANALYYSI – THREAT HUNTING

DEMO 5

elisa

ANALYYSI – THREAT HUNTING

TÄRKEIMMÄT HUOMIOT

1. Käytä useampia hakusanoja, saatat yllättyä!
2. Ymmärrä, miten hakuja rakennetaan
3. Tutustu eri tauluihin ja mitä dataa näistä löytyy
4. Muista mahdolliset GDPR / tietosuojakulmat
5. Tietosuojavaltuutetun lista on hyvä aloituskohta tilimurtotutkinnalle, laajenna tarvittaessa!

elisa

TUTKINNAN RAPORTOINTI

“The final phase is reporting, which is the process of preparing and presenting the information resulting from the analysis phase”.

- NIST SP 800-86

RAPORTOINTI - TUTKINNAN TULOKSET

TUTKINTAKYSYMYS	TULOS	HUOMIO
Onko tileille tullut luvattomia uudelleenlähetyssääntöjä?	Kyllä, tietyn lähettäjän viestit ohjataan RSS kansioon ja merkitään luetuksi.	Sähköpostilaatikkoon asetetun sähköpostin käsittelysäännön nimi oli ”1”
Jos on, mihin sähköpostiosoitteeseen ne johtavat?	Sähköposteja ei lähetetä edelleen organisaation ulkopuolelle.	Uhkatoimijan käsittelysääntö nojaa siihen, että hänellä tulee olemaan pääsy tilille
Onko tilille kirjauduttu luvattomasti tuona aikana (esimerkiksi Azure AD -tunnuksen audit log)?	Kyllä, kirjautumistapahtumia poikkeavasta IP osoitteesta n. 10 minuutin aikaikkunassa.	Uhkatoimijan kirjautumiset ajoittuvat: 2025-02-19T11:39:30.1919385Z – 2025-02-19T23:45:30.6616776Z
Jos kirjautumisia on tapahtunut, onko sähköposteja ladattu (esimerkiksi Office 365 Exchange -lokit)?	Kyllä, uhkatoimija luki kaksi sähköpostia. Uhkatoimijan aktiviteetti rajattu haitalliseksi tunnistetun Entra ID Session ID arvon pohjalta	Viestin Internet Message ID arvot: DB9PR08MB9804AD7A4539091FC82FB90B91C52@DB9PR08MB9804.eurprd08.prod.outlook.com DB9PR08MB9804F7230D043D2519951FDB91C52@DB9PR08MB9804.eurprd08.prod.outlook.com
Onko tilillä ollut käytössään OneDrive- tai Sharepoint-palveluita?	Kyllä	Uhkatoimija katsoi (FileAccessed) ja latasi (FileDownloaded) useita tiedostoja hyökkäyksen aikana
Onko tilien sähköposteissa, OneDrivessa tai Sharepoint-palveluissa henkilötietoja?	Kyllä	Ladatuissa tiedostoissa sensitiivistä tietoa: Henkilöstö.xlsx Liikesalaisuus.docx
Jos on, kuinka monen henkilön tietoja näissä palveluissa on ja mihin henkilötietoryhmiin ne kuuluvat (esimerkiksi nimi, henkilötunnus, sähköposti, osoite)?	Kahden henkilön tiedot vaarantuneet	Henkilöstö.xlsx sisälsi työntekijän nimen, henkilötunnuksen, sähköpostiosoitteen ja tittelin
Onko organisaatiossa harkittu käytettäväksi monen tekijän tunnistautumista (MFA)?	Kyllä	Uhkatoimija ohitti MFA tunnistautumisen käyttämällä AiTM tekniikkaa
Miten paljon ja mitä henkilötietoryhmiä organisaation Global Address List sisältää?	-	-
Toimita tietosuojavaltuutetun toimistolle vuodettujen tunnusten osalta niiden Azure AD:n SIGN-INS -loki hyökkäyksen ajalta (csv-tiedosto)	Linkki toimitettu erikseen	Kirjautumistapahtumat kerätty Microsoft Defender XDR Advanced Hunting toiminnallisuutta käyttäen, taulu: AADSignInEventsBeta. Haitalliset kirjautumiset eroteltu uhkatoimijan IP osoitteeseen
Toimita hyökkääjien lähettämä sähköposti, joka sisältää linkit.	Uhkatoimijan pääsystä ei ole enää jälkiä	-
Toimita mailtrace-loki hyökkääjän lähettämien sähköpostien osalta.	-	-

TUTKINNAN RAPORTOINTI

“As part of the reporting process, analysts should identify any problems that may need to be remedied, such as policy shortcomings or procedural errors. Many forensic and incident response teams hold formal reviews after each major event”.

- NIST SP 800-86

SUOSITUKSET

1. 72h ilmoitusvelvollisuus! Ei tarvitse olla valmis raportti
2. Jokainen tilimurto tulee tutkia tarkasti, pelkkiin hälytyksiin ei aina voi luottaa
3. Käyttäkää phishingin kestävää MFA menetelmää (passwordless / FIDO2)
4. Conditional Access Policyt kuntoon!
5. Oman organisaation tunnusten seuranta ”dark webissä”

CONTACTS

/in/juuso-myllyla

juuso.myllyla@elisa.fi

https://yrityksille.elisa.fi/kyberkonsultointi
#tietomurto

KIITOS!